27-10-2026

ACTIVIDAD 04: OWASP ZAP – PRIMERA EVALUACIÓN DE SEGURIDAD WEB – GIN & JUICE SHOP

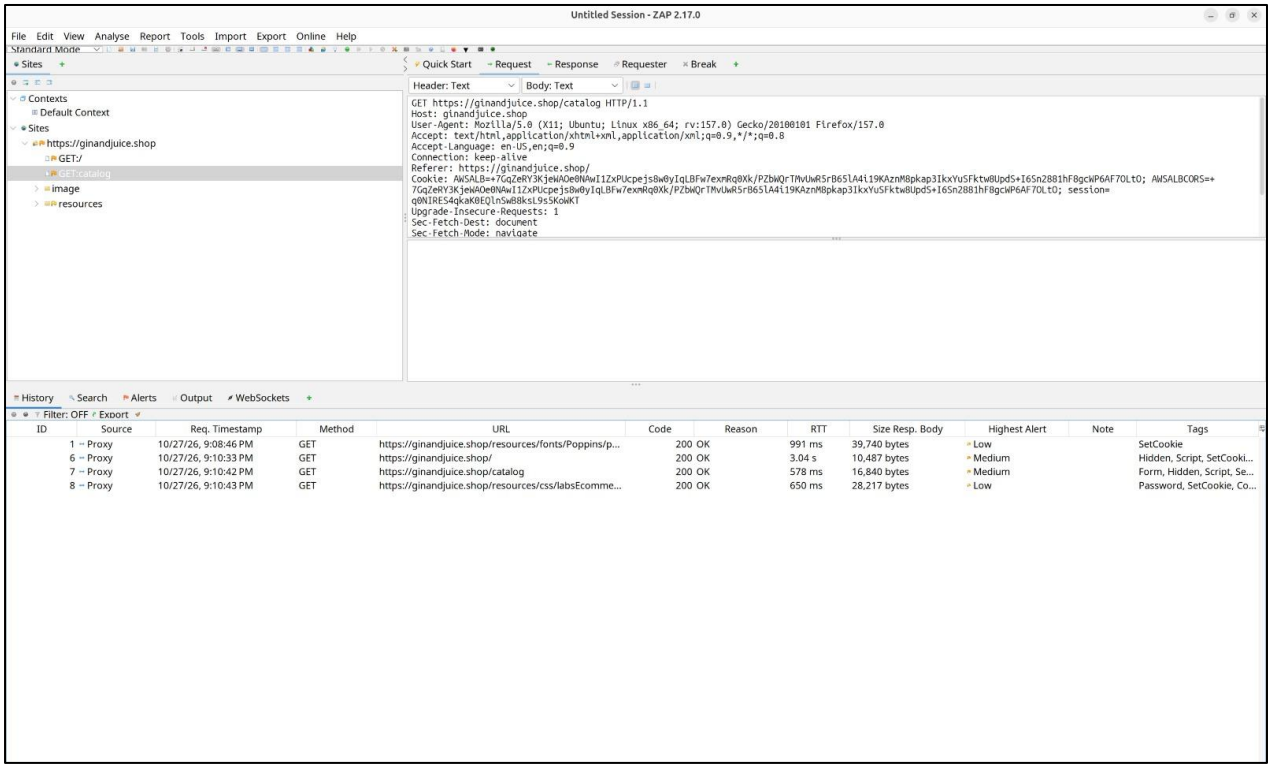
HACKER WOMEN COUNCIL – ETHICAL HACKER

Instructora: Aleida Pérez

Alumna: Valentina Belén Dolce

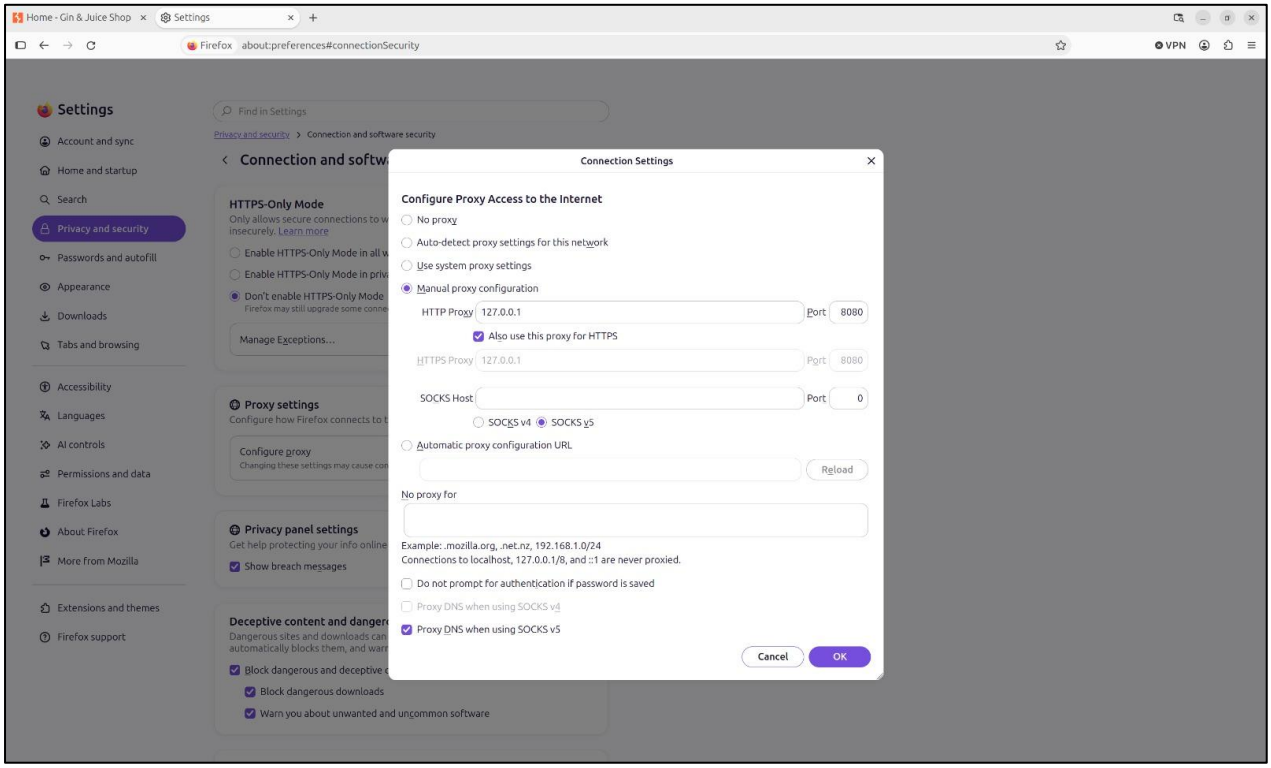
1. PREPARA TU ENTORNO: Documenta 4 elementos.

01- Zap abierto



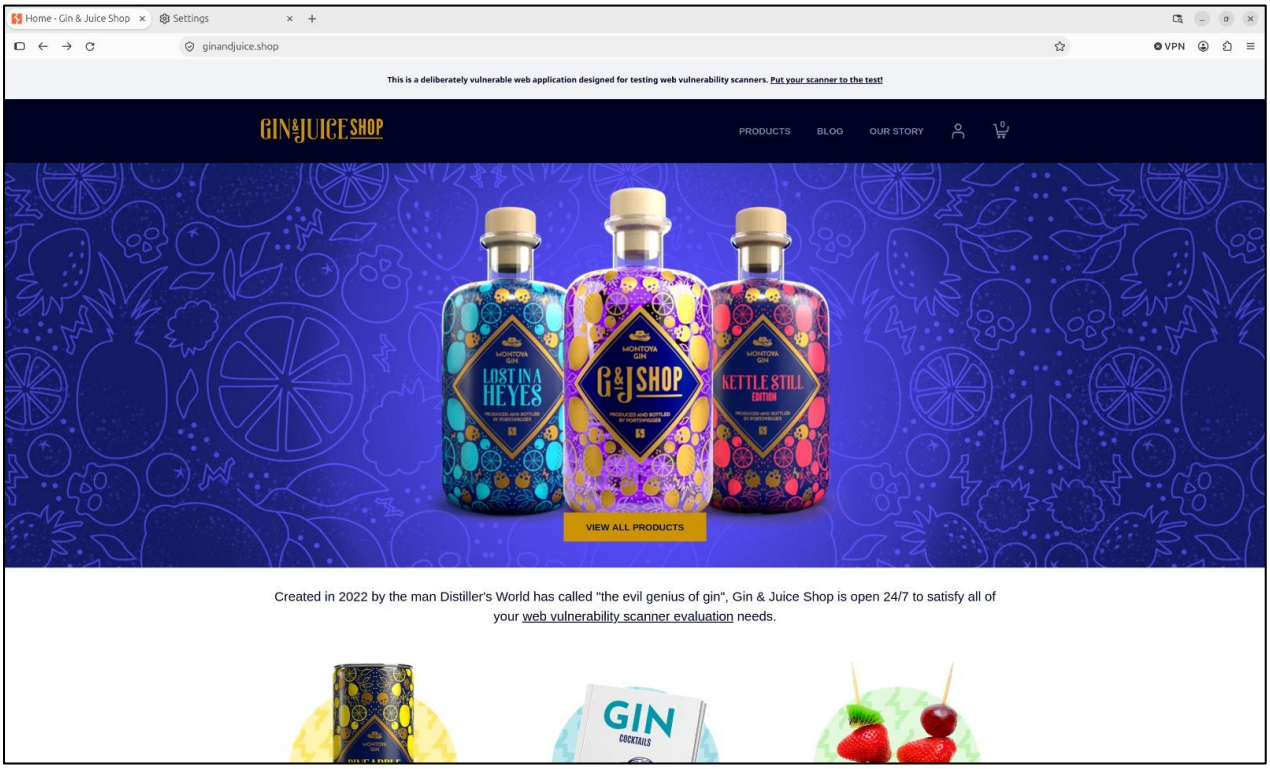
Captura de la interfaz principal de ZAP

02- Navegador configurado.



Captura de la conexión de proxy en mi navegador

03- Acceso a https://ginandjuice.shop/



Página de inicio de https://ginandjuice.shop/

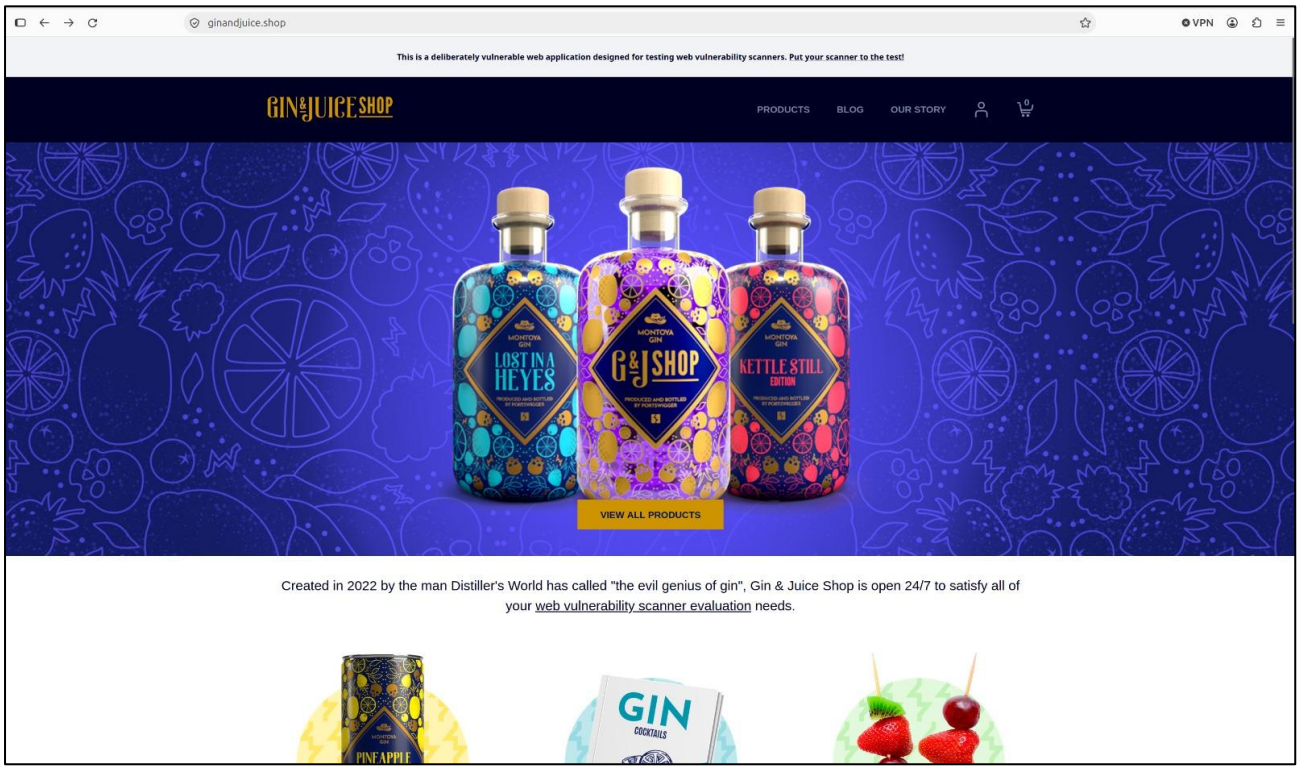
04- Verificación de que el tráfico aparece en ZAP



1 – Proxy	10/27/26, 9:08:46 PM	GET	https://ginandjuice.shop/resources/fonts/Poppins/p...	200 OK	991 ms	39,740 bytes	Low	SetCookie
6 – Proxy	10/27/26, 9:10:33 PM	GET	https://ginandjuice.shop/	200 OK	3.04 s	10,487 bytes	Medium	Hidden, Script, SetCooki...
7 – Proxy	10/27/26, 9:10:42 PM	GET	https://ginandjuice.shop/catalog	200 OK	578 ms	16,840 bytes	Medium	Form, Hidden, Script, Se...

Interceptación de tráfico mediante ZAP

2. EXPLORA LA APLICACIÓN: Documenta 5 elementos



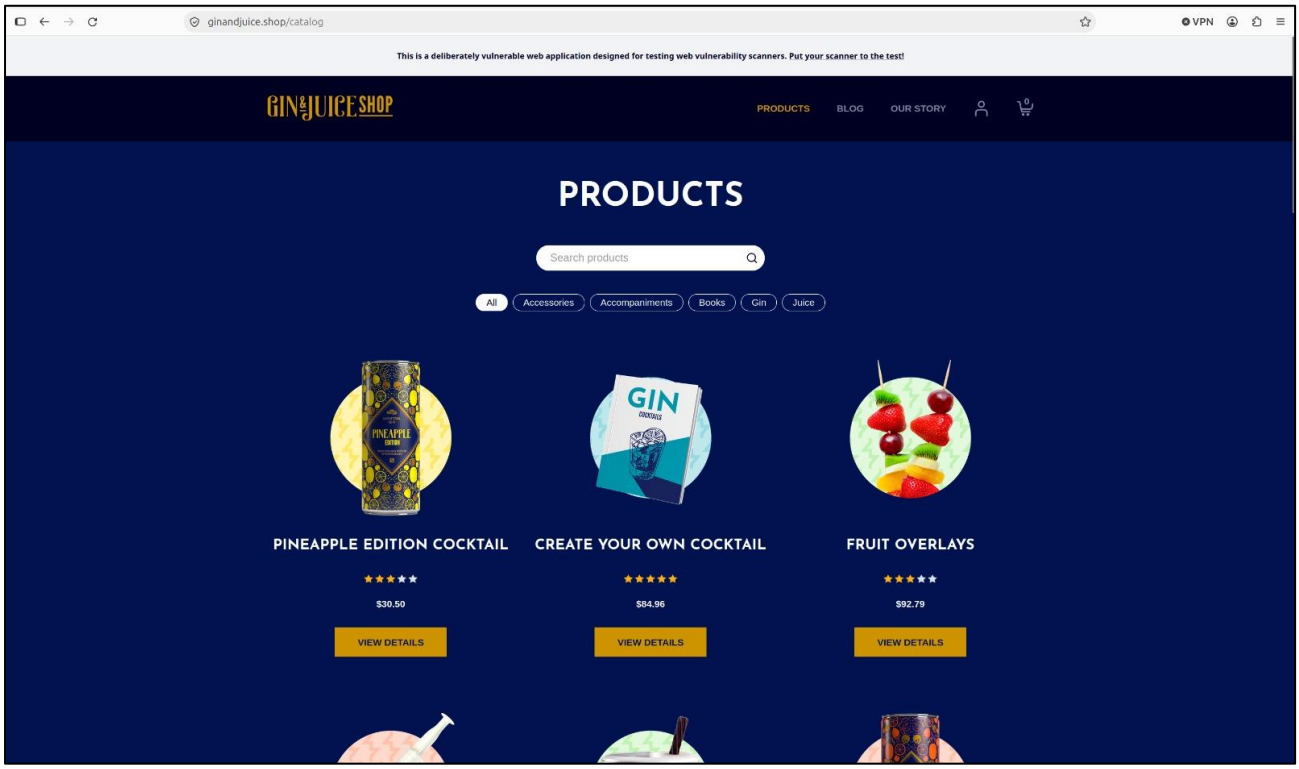
01-

Página de inicio



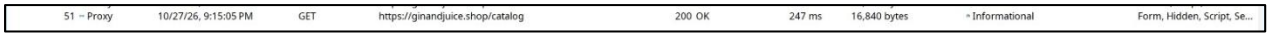
50 – Proxy	10/27/26, 9:14:12 PM	GET	https://ginandjuice.shop/	200 OK	1.13 s	10,487 bytes	Hidden, Script, SetCooki...

Tráfico HTTP capturado en ZAP, de la página de inicio

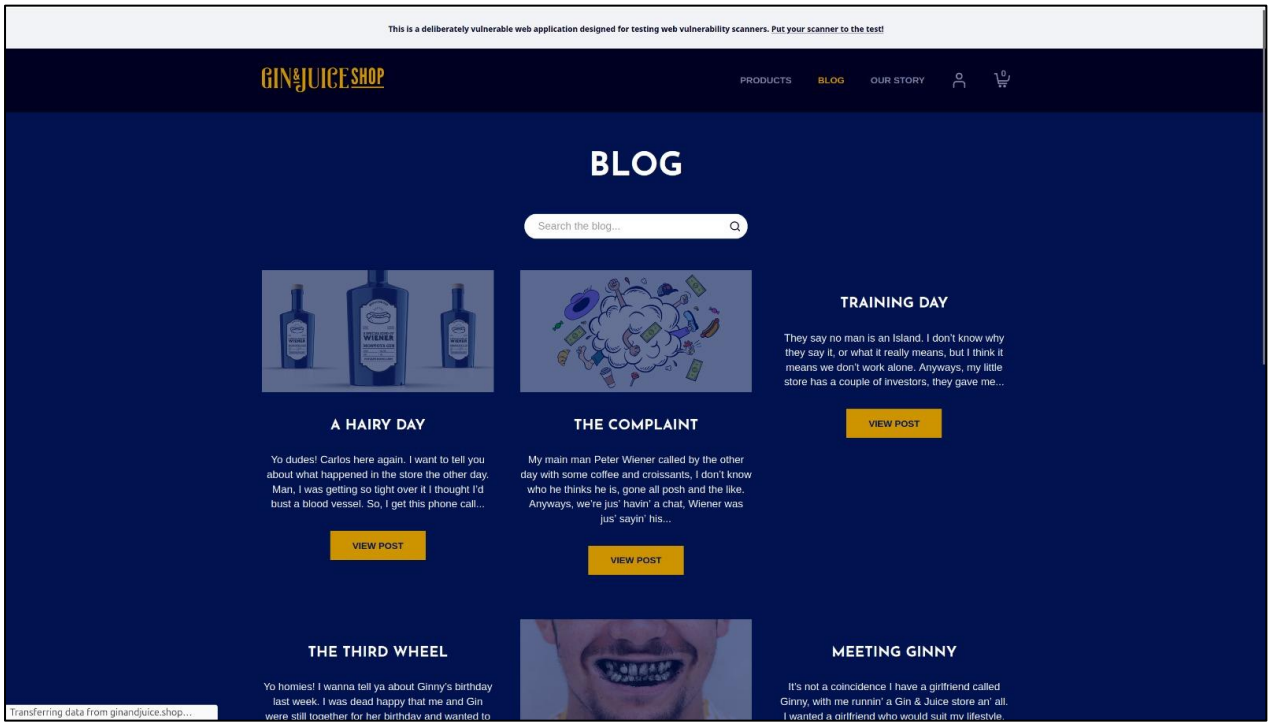


02-

Sección “catalog”, donde podemos observar los productos que ofrecen

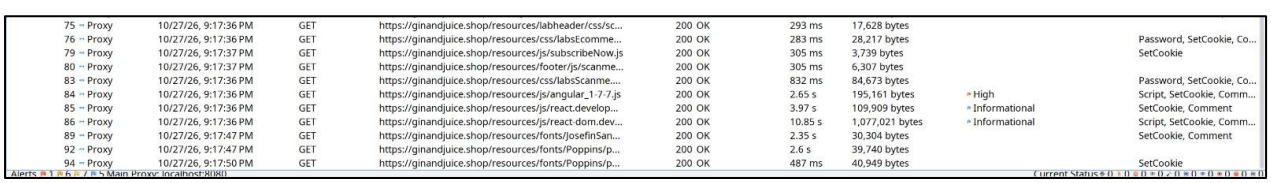


Tráfico HTTP capturado en ZAP al navegar por la sección “Catalog”

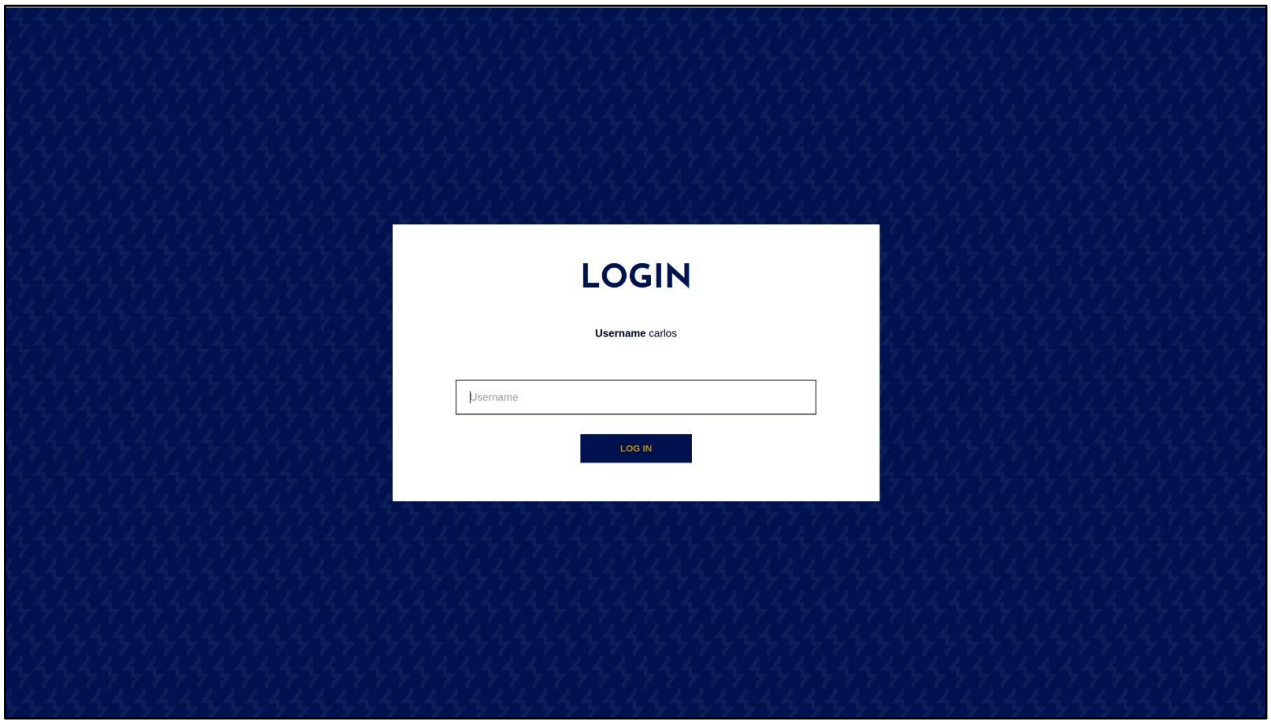


03-

Sección “Blog”, donde podemos observar posteos de clientes contando sus experiencias



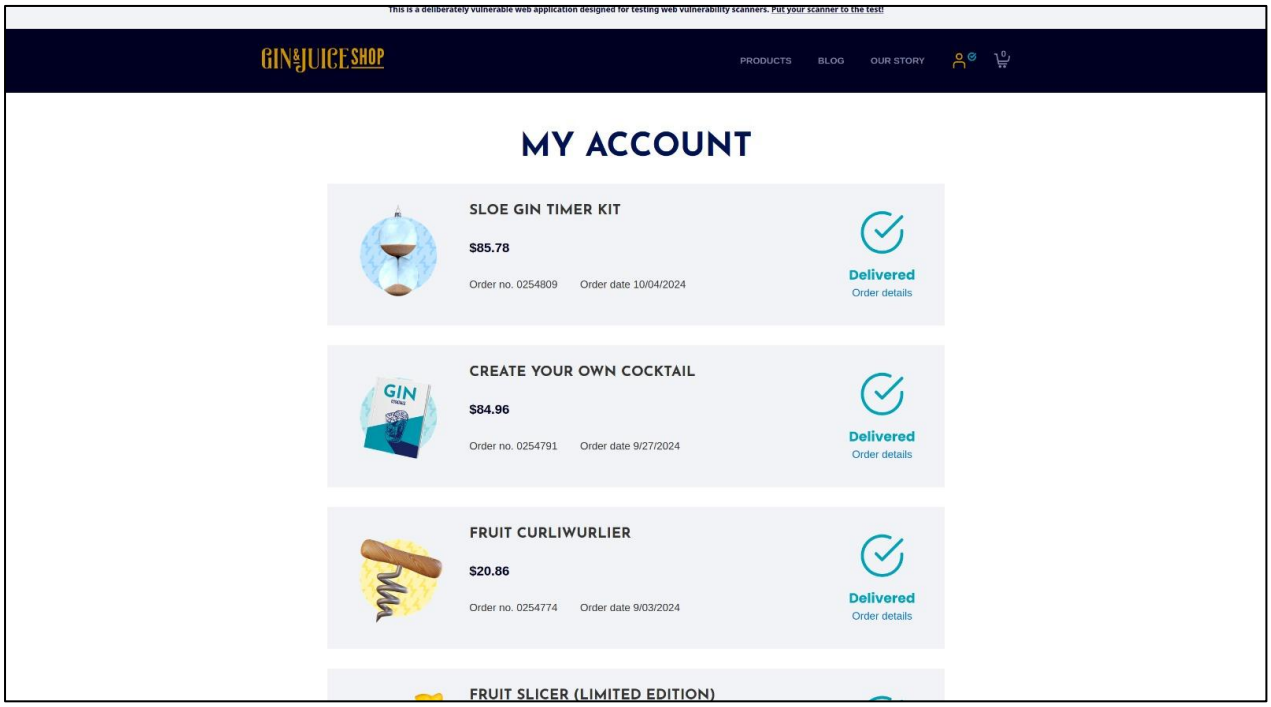
Tráfico HTTP capturado en ZAP al navegar por la sección “Blog”

04- 

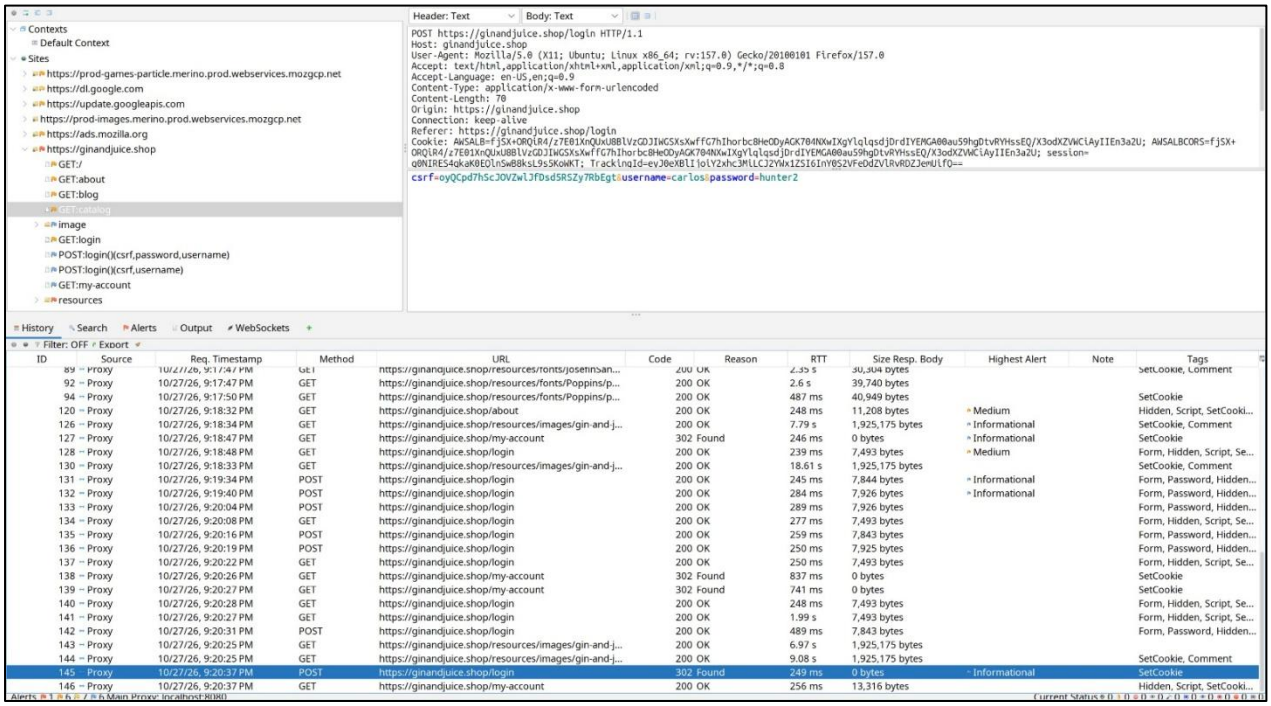
Sección “Login”, donde podemos observar el campo te texto para completar usuario y contraseña



Tráfico HTTP capturado en ZAP al navegar por la sección “Login”

05- 

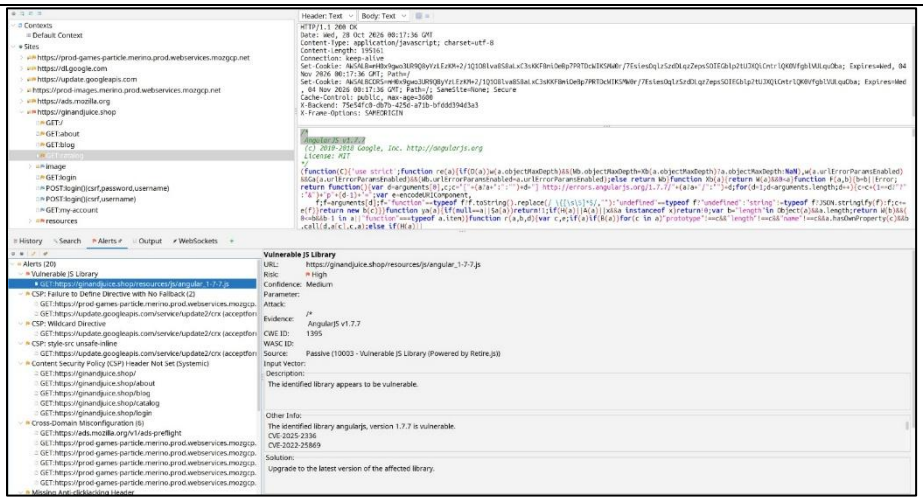
Sección “My account”, donde podemos observar los productos adquiridos y su estado



Tráfico HTTP capturado en ZAP al navegar por la sección “My account”

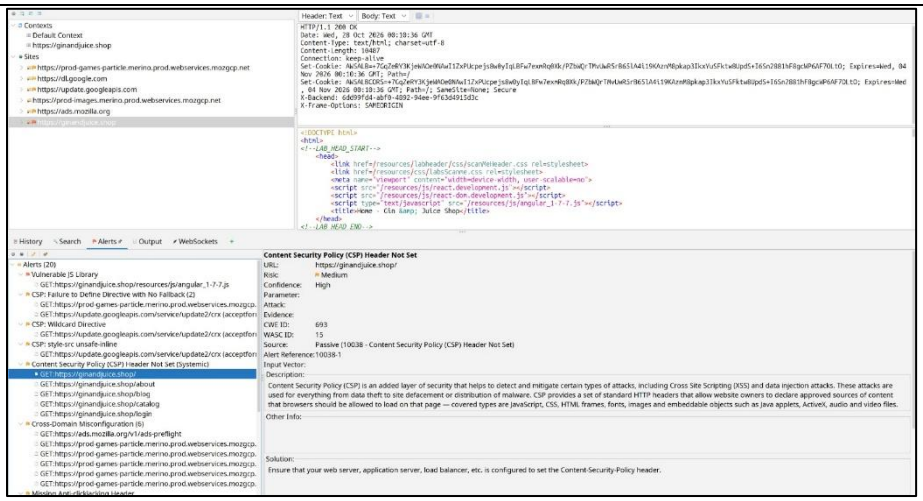
3. ANALIZA LAS ALERTAS: Documenta 3 alertas de diferentes tipos.
4. DOCUMENTA UN HALLAZGO PRINCIPAL: Elije 1 alerta y completa una ficha técnica con 8 elementos

01-

1	Nombre de la alerta	JS Library vulnerable
2	Nivel de riesgo	Alto
3	URL o componente	https://ginandjuice.shop/resources/js/angular-1-7-7.js
4	Parámetro afectado	No aplica
5	Evidencia	 AngularJS v1.7.7 detectado por ZAP/Retire.js. CVE-2025-2336 y CVE-2022-25869. CWE-1395.

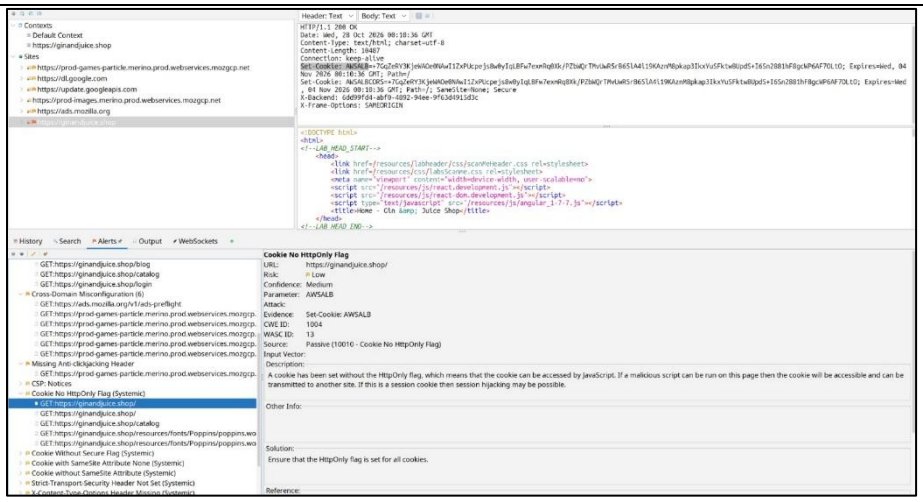
6	Descripción técnica	La aplicación utiliza una versión de AngularJS cuyo soporte oficial finalizó en enero de 2022 y que presenta vulnerabilidades conocidas.
7	Impacto potencial	Potenciales ataques XSS, suplantación de contenido o alteraciones del comportamiento, dependiendo de las condiciones de explotación.
8	Recomendación	Migrar a un framework mantenido, revisar dependencias y validar mediante pruebas de regresión y seguridad.

02-

1	Nombre de la alerta	Cabecera de Content Security Policy no configurada
2	Nivel de riesgo	Medio
3	URL o componente	https://ginandjuice.shop/
4	Parámetro afectado	No aplica.
5	Evidencia	 Análisis pasivo de ZAP, regla 10038. Ausencia del encabezado Content-Security-Policy en la respuesta HTTP. CWE-693.
6	Descripción técnica	El servidor no define una política CSP que restrinja las fuentes desde las que el navegador puede cargar contenido.
7	Impacto potencial	Menor protección frente a ataques XSS e inyecciones de contenido.
8	Recomendación	Implementar una CSP restrictiva y validarla para evitar romper funcionalidades legítimas.

03-

1	Nombre de la alerta	Cookie sin el flag HttpOnly
2	Nivel de riesgo	Bajo
3	URL o componente	https://ginandjuice.shop/
4	Parámetro afectado	AWSALB

5	Evidencia	 Encabezado Set-Cookie: AWSALB=... sin atributo HttpOnly
6	Descripción técnica	La cookie puede ser accesible desde JavaScript porque carece del atributo HttpOnly.
7	Impacto potencial	Un script malicioso ejecutado en el mismo origen podría leer la cookie
8	Recomendación	Evaluar si puede utilizarse HttpOnly y verificar que las cookies de autenticación estén protegidas

5. CONCLUSIONES: Documenta 3 elementos

01- ¿Qué aprendí?

Aprendí a utilizar OWASP ZAP para interceptar y analizar tráfico HTTP/HTTPS, identificar alertas de seguridad y examinar las respuestas del servidor. También comprendí la importancia de distinguir entre vulnerabilidades potenciales, configuraciones inseguras y riesgos efectivamente demostrados.

02- ¿Qué fue lo más retador?

Lo más desafiante fue interpretar correctamente las alertas, especialmente porque ZAP también registró tráfico de servicios externos al sitio evaluado. Fue necesario delimitar el alcance y analizar los detalles técnicos de cada hallazgo para evitar conclusiones incorrectas.

03- ¿Qué revisaría a continuación?

Profundizaría en las vulnerabilidades asociadas a AngularJS 1.7.7, comprobaría qué funcionalidades utilizan la biblioteca y evaluaría las posibilidades de explotación en un entorno autorizado. También revisaría la configuración de CSP y la protección de las cookies de autenticación. Finalmente, realizaría pruebas adicionales para validar los hallazgos y descartar falsos positivos.